

Aplicaciones de IA en Ciberseguridad

Jesús Fernández Bes



2026
CURSOS DE VERANO
Universidad Complutense de Madrid

ZARAGOZA

QUIÉN SOY

- Senior Data Scientist & AI Engineer @ Plain Concepts.
- Profesor de Machine Learning en USJ · Grupo de investigación COMBA.
- Ph.D. en Ingeniería de Telecomunicación en la UC3M.
- +15 años de experiencia en IA aplicada.

Vengo desde la IA aplicada, no desde las operaciones de ciberseguridad.



plain
concepts

from thought
to value

CONTENIDOS

1

INTRODUCCIÓN

2

IA PREDICTIVA

3

IA GENERATIVA

4

CONCLUSIÓN

1

INTRODUCCIÓN

PORQUÉ NOS INTERESA LA CIBERSEGURIDAD PARA APLICAR IA

- **Volumen masivo** de eventos y señales — imposible procesar manualmente.
- Los **ataques** relevantes son **raros**.
- **Decisiones costosas** con alta presión temporal.
- La **información útil está dispersa** en logs, flujos, alertas y documentación.

Necesidad de automatizar
decisiones en contextos de
incertidumbre

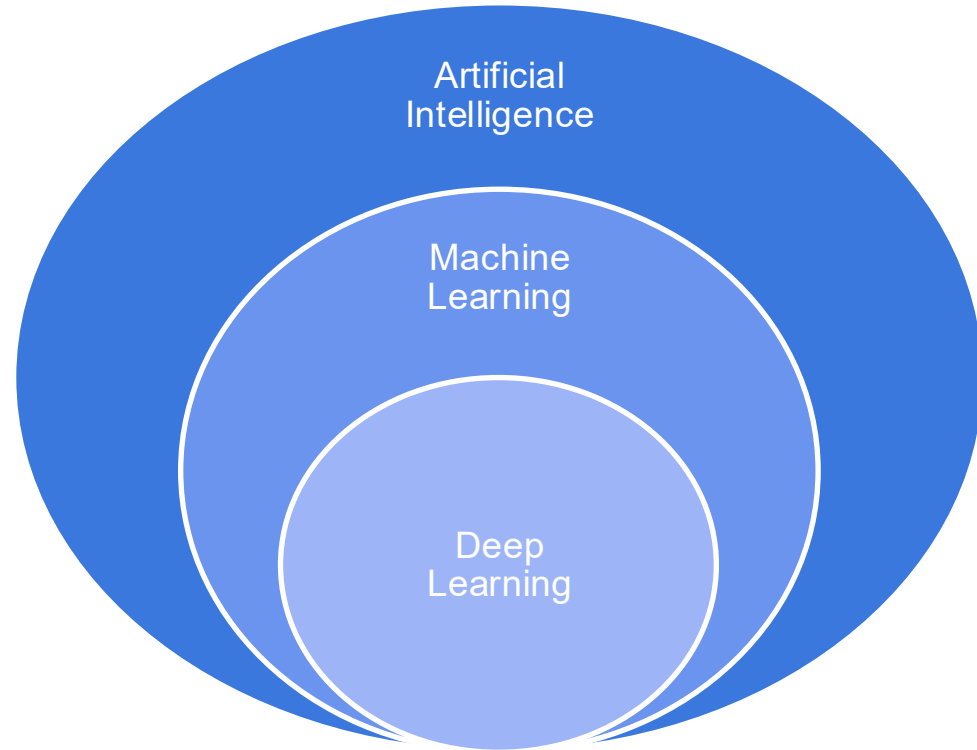


INTELIGENCIA ARTIFICIAL VS. MACHINE LEARNING VS. DEEP LEARNING

Inteligencia Artificial es la disciplina que trata de proporcionar capacidades a los sistemas informáticos tales como percepción, razonamiento, resolución de problemas, uso del lenguaje, aprendizaje.

Aprendizaje automático (*Machine Learning*) es una rama de la Inteligencia Artificial. Se basa en el uso de datos para construir modelos para resolver tareas o hacer predicciones sin hacer programación explícita.

Aprendizaje Profundo (*Deep Learning*) es una parte del Aprendizaje Automático que utiliza Redes Neuronales Artificiales de muchas capas (profundas).



DOS PARADIGMAS DE IA APLICADA

IA predictiva – Herramienta

Creada para una tarea

- Entrada: datos estructurados, flujos, logs
- Salida: clasificación, puntuación, alerta
- Rol humano: revisar y actuar sobre resultados
- Métricas: precisión, *recall*, tasa de falsos positivos



IA generativa – Asistente

Propósito general

- Entrada: texto, documentos, historial de incidentes
- Salida: resumen, hipótesis, respuesta, acción sugerida
- Rol humano: guiar, validar y decidir
- Métricas: utilidad real, trazabilidad, confianza

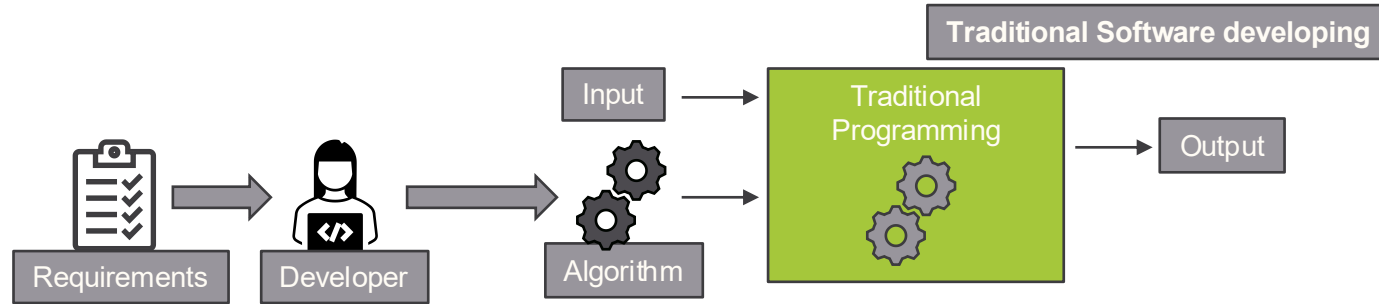


2

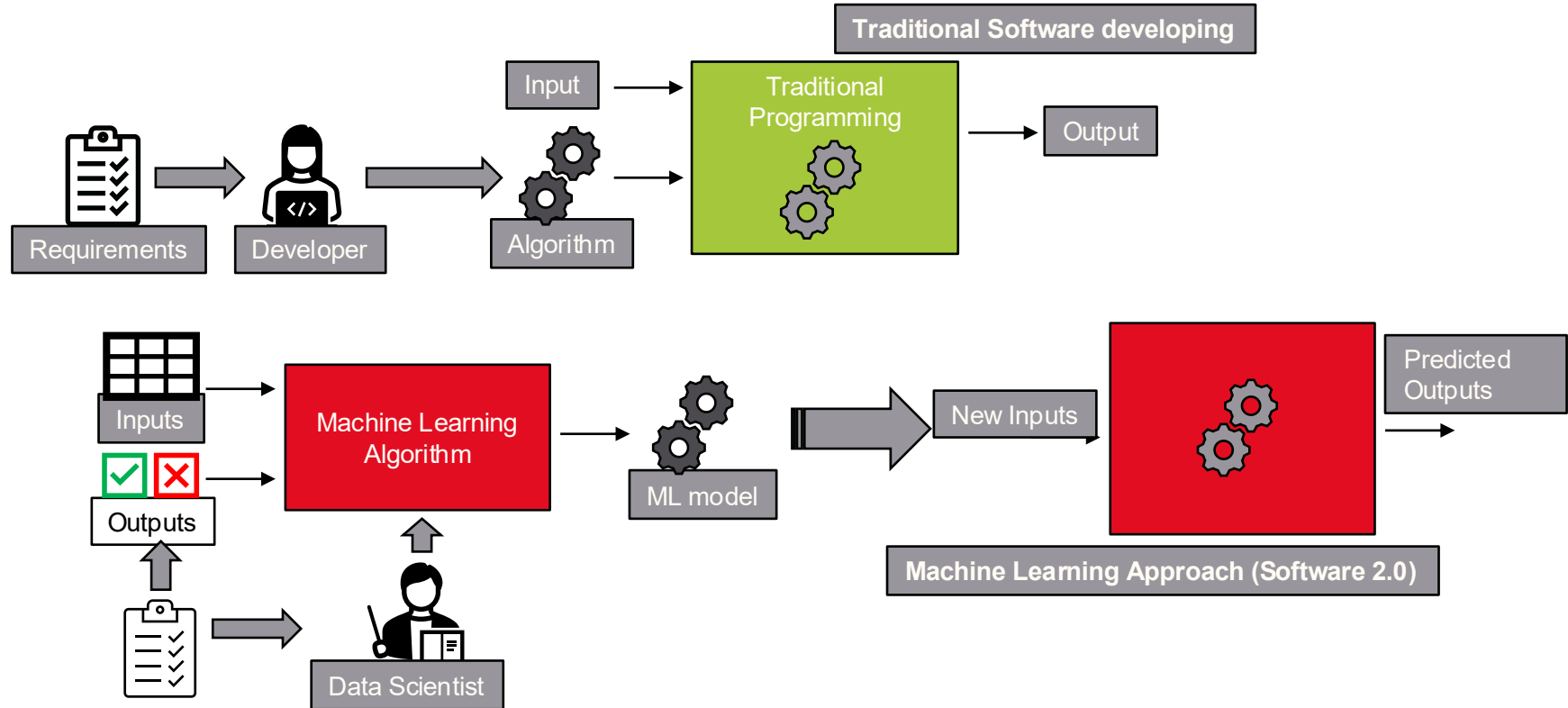
IA Predictiva

*Aprendizaje Automático y su uso en
Ciberseguridad*

MACHINE LEARNING COMO SOFTWARE 2.0

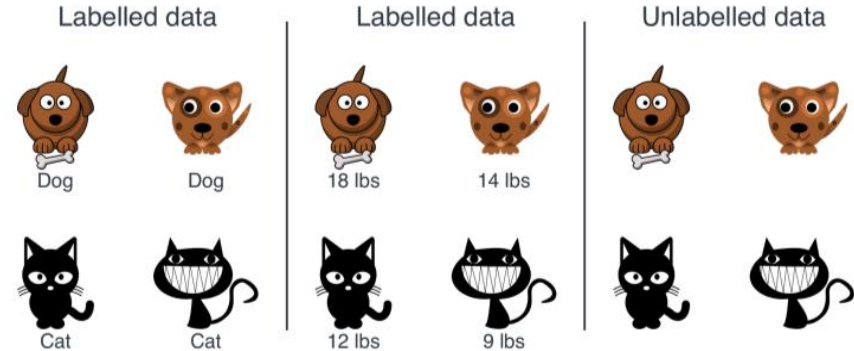


MACHINE LEARNING COMO SOFTWARE 2.0

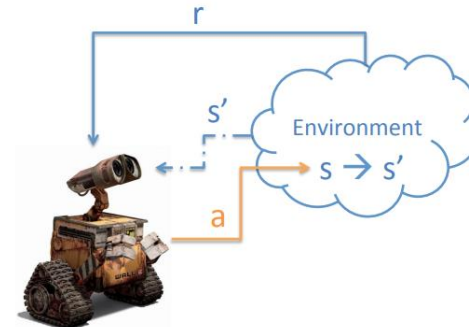


ENFOQUES EN APRENDIZAJE AUTOMÁTICO

- **Aprendizaje supervisado.** El algoritmo se diseña utilizando datos etiquetados.
 - Regresión
 - Clasificación
- **Aprendizaje no supervisado.** El algoritmo está diseñado utilizando datos sin etiquetar.
 - Agrupamiento (Clustering)
 - Reducción de dimensionalidad
- **Aprendizaje por refuerzo.**
Aprender un comportamiento



Serrano, L. (2021). *Grokking Machine Learning*. Simon and Schuster.



ENFOQUES EN APRENDIZAJE AUTOMÁTICO

• Aprendizaje supervisado. El

algoritmo se
datos etique

- Regresión
- Clasificación

• Aprendizaje no

algoritmo es
datos sin et

- Agrupación
- Reducción

• Aprendizaje por

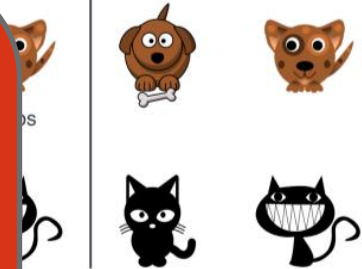
Aprender un comportamiento

Labelled data

Labelled data

Unlabelled data

En Ciberseguridad el
enfoque tiende a ser
supervisado



learning. Simon and Schuster.



a

ent
s'

APLICACIONES DE APRENDIZAJE AUTOMÁTICO

IDS — Detección de intrusiones	Clasificar si el tráfico de red o los eventos de sistema corresponden a comportamiento legítimo o a un ataque. Los ataques son eventos rarísimos frente al tráfico legítimo, y el coste de un falso positivo — una alerta que nadie revisa o que bloquea tráfico legítimo — es operativamente muy alto.
Detección de malware estático	Si un fichero ejecutable es malicioso antes de ejecutarlo, a partir de características extraídas del binario: histograma de bytes, cabeceras PE, secciones, importaciones, cadenas de texto.
Detección de phishing	Identificar URLs, páginas web o correos que intentan suplantar entidades legítimas para robar credenciales. Los ataques evolucionan rápido, las campañas duran horas, y un modelo entrenado sobre phishing de hace seis meses puede no generalizar bien al phishing de hoy.
Detección de fraude	El modelo produce una puntuación de riesgo sobre cada transacción financiera. El fraude puede ser 1 de cada 10.000 transacciones, lo que hace que las métricas estándar sean engañosas. Área de aplicación muy desarrollada por banca.
Priorización de alertas (Alert triage)	Un SOC puede recibir decenas de miles de alertas al día de sistemas SIEM, IDS y EDR. La mayoría son falsos positivos o eventos de baja relevancia. ML se usa aquí no para detectar el ataque sino para ordenar las alertas: cuál merece atención inmediata, cuál puede esperar, cuál es probablemente ruido.

CASO 1: DETECCIÓN DE INTRUSIONES COMO PROBLEMA DE APRENDIZAJE

- **Entrada:** flujos de red, logs de sistema, comportamiento de procesos
- **Tarea:** clasificación (ataque / normal) o detección de anomalías
- **Salida:** puntuación de riesgo o alerta para el analista
- **Retos:**
 - Los ataques son eventos raros
 - Coste asimétrico del error: un falso negativo puede ser catastrófico; un falso positivo agota al equipo.



VALIDACIÓN DE SISTEMAS DE *ML* EN CIBERSEGURIDAD



Red Flags

- ▶ Datos no representativos (antiguos, sesgados, sintéticos).
- ▶ Evaluación no rigurosa.
- ▶ Métricas no ligadas al coste operativo real.
- ▶ Comparativa contra sistemas "débiles".

Necesario:

- Comparar contra sistemas de referencia ya competentes.
- Métricas que importan en producción.

CASO 2: EMBER (MALWARE ESTÁTICO)

EMBER

Dataset público de PE estáticos (.exe, .dll,...)— 1M de muestras etiquetadas

1. Dos aproximaciones comparadas:

- **MalConv**: modelo profundo de extremo a extremo sobre bytes crudos
- Variables diseñadas (histogramas, cabeceras, imports, cadenas) + **Gradient Boosted Decision Trees**

Más profundo no equivale a mejor

ALGUNAS HERRAMIENTAS COMERCIALES



CrowdStrike Falcon — el referente del mercado EDR. El agente incorpora modelos de ML entrenados sobre billones de eventos para detectar malware conocido y desconocido antes de la ejecución.



SentinelOne Singularity — plataforma XDR que combina ML estático (análisis pre-ejecución) con inspección comportamental en tiempo real. Puede responder de forma autónoma sin intervención humana.



Microsoft Defender
for Endpoint

Microsoft Defender for Endpoint — presente en la mayoría de los entornos corporativos Windows por defecto. Usa ML a escala sobre la telemetría de millones de dispositivos (Microsoft Threat Intelligence). Quizás el más desplegado del mundo, aunque no siempre el más reconocido como "producto de ML" por los equipos de seguridad.



Darktrace — pionero en aplicar ML no supervisado al tráfico de red. Aprende un modelo de "comportamiento normal" para cada usuario y dispositivo y detecta desviaciones. Especialmente conocido para detectar movimiento lateral y amenazas internas.

LÍMITES DE LA IA PREDICTIVA

- Necesitas **datos etiquetados** y etiquetarlos cuesta.
- Necesitas un **equipo de *data science***.
- El modelo **se degrada** con el tiempo.
- Integración con la **infraestructura existente**.
- **Interpretabilidad** limitada.

- Caro
- Difícil de construir
- Difícil de usar
- Número de “usos limitados”



Pero los cirujanos siguen operando con bisturís desechables

3

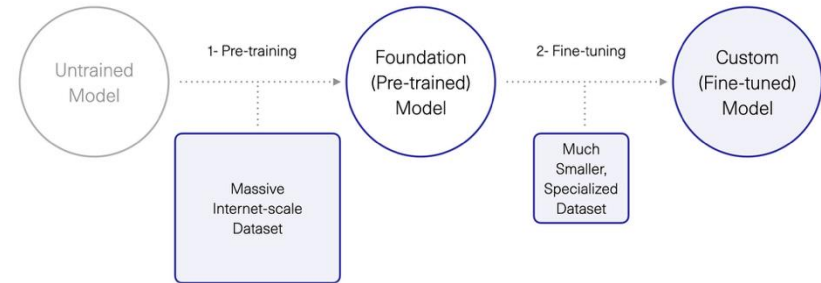
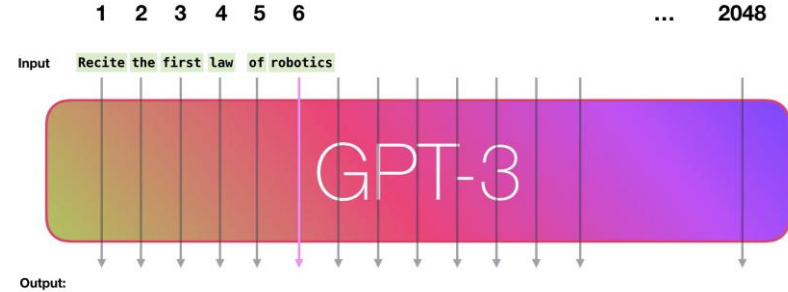
IA Generativa

Algo pasó a partir de 2020...



LARGE LANGUAGE MODELS (LLMs)

- Redes Neuronales basadas en la arquitectura **Transformer**.
- Pre-entrenados para predecir la siguiente “palabra”.
 - Cierta "comprensión del lenguaje”.
- Cada vez más **grandes** y **caros** en:
 - Datos.
 - Capacidad de computo.
- Creada por grandes empresas o start-ups bien fundadas.
- **Foundations** para construir sobre ellos.



ARQUITECTURA DE LA IA GENERATIVA

LLM — razonamiento y generación de lenguaje

Entiende preguntas, genera resúmenes, sugiere hipótesis.

RAG — recuperación de contexto relevante

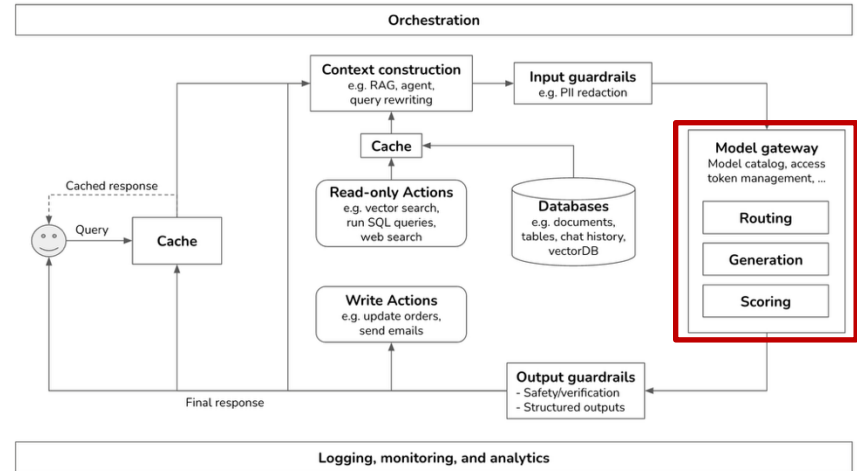
Playbooks, alertas históricas, documentación técnica, threat intel.

Herramientas — acceso a datos en tiempo real

Consultas a SIEM, SOAR, bases de datos, APIs

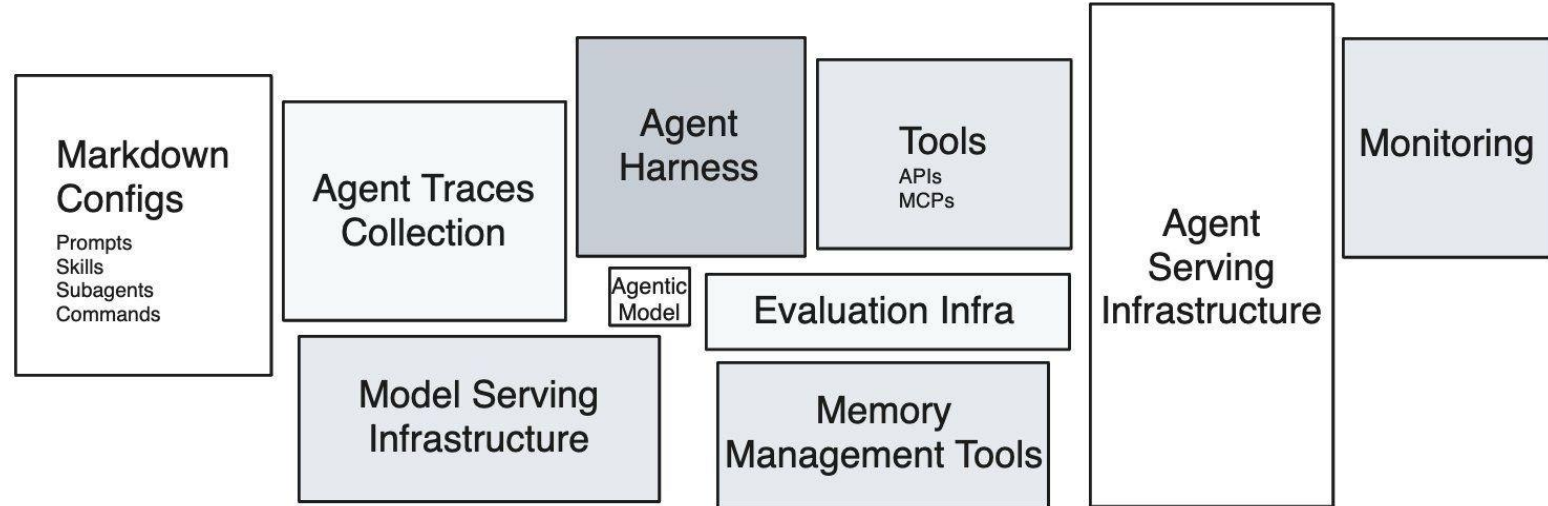
Agentes — coordinación y acción supervisada

Encadenan pasos, delegan subtarefas, mantienen estado

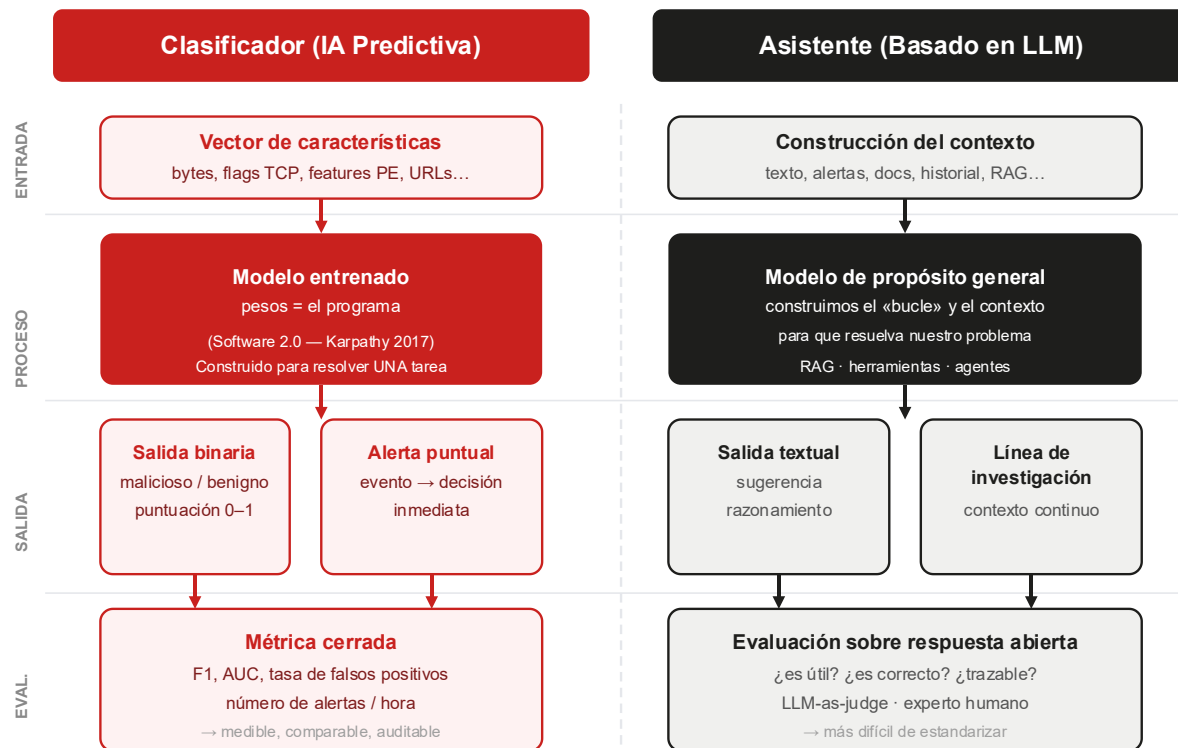


Lo decisivo no es el LLM aislado, sino el sistema completo

¿¿EL MODELO ES LO DE MENOS?



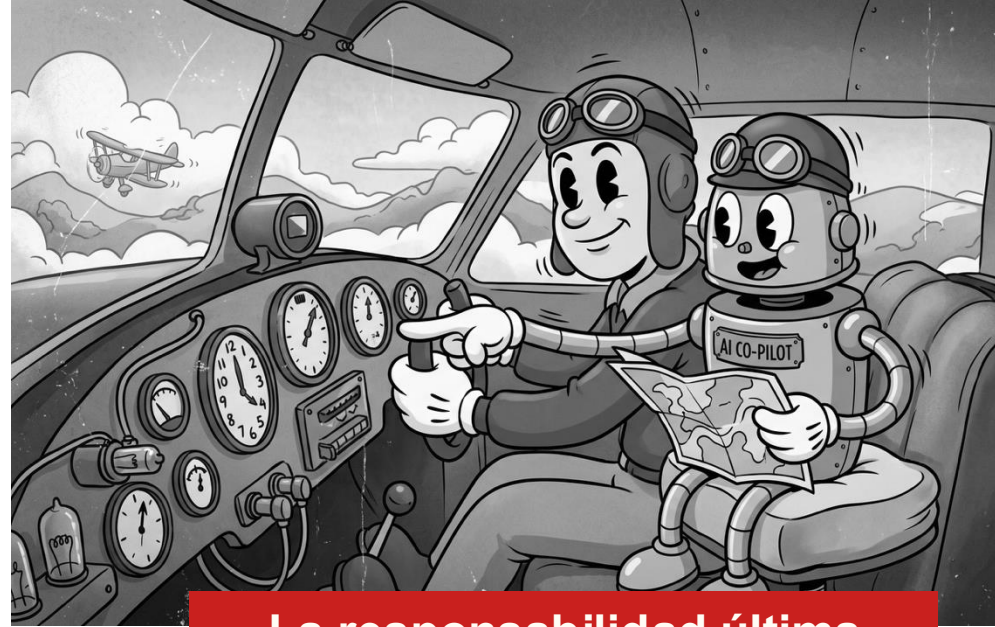
UN CAMBIO DE PARADIGMA



Caso 3: copiloto para un analista SOC

Flujo de trabajo con copiloto:

1. **Llega una alerta** → el copiloto recupera contexto relevante (logs, CVEs, activos afectados, casos similares)
2. **Resume evidencias** disponibles en lenguaje claro — trazabilidad de fuentes incluida.
3. **Sugiere hipótesis** y líneas de investigación ordenadas por probabilidad
4. **El analista decide, guía y valida cada paso** — el sistema no ejecuta acciones de alto impacto sin aprobación explícita.
5. **El copiloto documenta** y mantiene continuidad del caso — log auditable de razonamientos y acciones



**La responsabilidad última
permanece en el analista**

APLICACIONES DE LA IA GENERATIVA

Resumen de alertas e incidentes complejos con múltiples fuentes.

Búsqueda semántica en documentación técnica y playbooks.

Generación y ejecución de consultas para SIEM, SOAR y plataformas de threat Intel.

Apoyo a redacción de informes y comunicación entre equipos.

Asistencia en formación, simulación y transferencia de conocimiento.

Análisis Estático de Malware.

TENDENCIA EN 2026: LLMS ESPECIALIZADOS

Claude Mythos 5 — Anthropic (jun 2026)

- Project Glasswing: +10.000 vulnerabilidades críticas encontradas con ~50 socios (AWS, Apple, Google, Microsoft...)
- Acceso restringido a partners verificados (150 orgs, 15 países). Retención de datos 30 días para monitorización de seguridad.

GPT-5.5-Cyber — OpenAI (may 2026)

- Trusted Access for Cyber (TAC): modelo más permisivo para red team, pentesting y validación en entornos autorizados
- Verificación de identidad obligatoria; acceso escalonado según nivel de confianza del operador

Sec-Gemini v1 — Google (abr 2025)

- Integra Google Threat Intelligence (GTI) + OSV (base de datos open source de vulnerabilidades)
- +11% en CTI-MCQ (benchmark de inteligencia de amenazas) frente a competidores. Acceso gratuito a organizaciones de investigación seleccionadas.

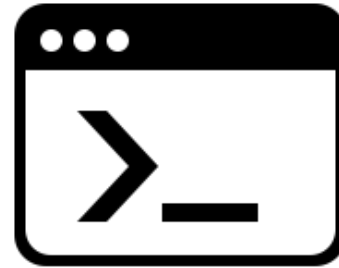
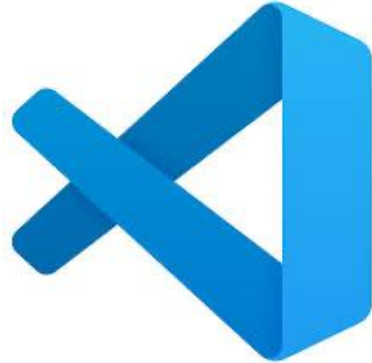
Patrón común: acceso controlado, verificación de identidad, orientados al defensor — no son herramientas de consumo masivo

 Claude

 Gemini


OpenAI

TENDENCIA EN 2026: USO INTEGRADO



<https://developers.openai.com/codex/security/plugin>

<https://claude.com/blog/automate-security-reviews-with-claude-code>

TENDENCIA EN 2026: FRAGMENTACIÓN DE HERRAMIENTAS



NUEVAS SUPERFICIES DE ATAQUE

La IA introduce nuevas superficies de ataque



Inyección de instrucciones

Prompt injection

El agente ejecuta instrucciones maliciosas embebidas en contenido que procesa (emails, documentos, resultados de búsqueda).

Agentes · LLMs



Envenenamiento de datos

Data / RAG poisoning

Corrupción del conjunto de entrenamiento o de la base RAG para inducir errores o sesgos en las respuestas del modelo.

Entrenamiento · RAG



Evasión adversarial

Adversarial examples

Muestra maliciosa modificada con perturbaciones mínimas para evadir clasificadores de malware o IDS.

IA predictiva · IDS



Agentes mal gobernados

Privilegios excesivos · Sin supervisión humana

Agente con permisos más amplios de lo necesario y sin puntos de control humano: un fallo tiene alcance máximo.

Agentes · CISA 2026

Este tema se desarrolla en detalle en la otra ponencia

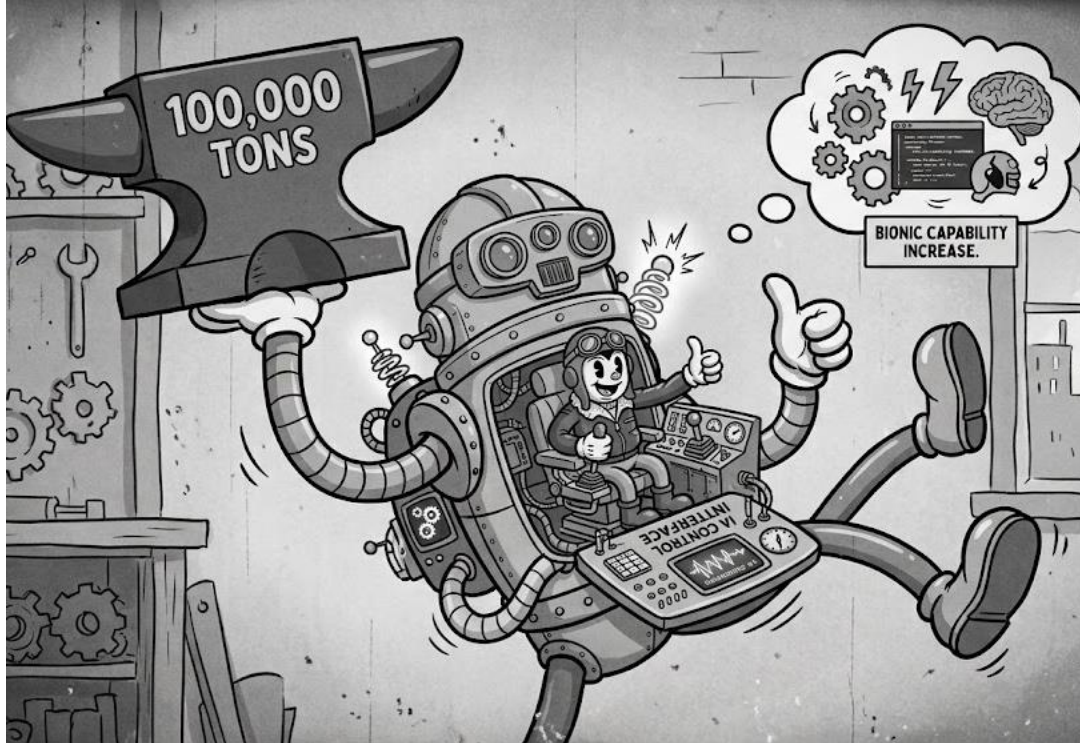
Límites de la IA generativa aplicada a seguridad



4

CONCLUSIÓN

CONCLUSIONES



La IA ya aporta valor en ciberseguridad:

- Productos y aplicaciones sólidas de **IA Predictiva**.
- Flujos de trabajo eficaces con **IA generativa**.

Valor cuando se combina con **conocimiento experto**:

- Aumento de capacidades del usuario.

Referencias

Marcos institucionales

- Tabassi, E. (2023). *AI Risk Management Framework (AI RMF 1.0)*. NIST AI 100-1. <https://doi.org/10.6028/NIST.AI.100-1>
- Autio, C. et al. (2024). *AI RMF: Generative AI Profile*. NIST AI 600-1. <https://doi.org/10.6028/NIST.AI.600-1>
- NIST (2025). *Adversarial Machine Learning: A Taxonomy and Terminology of Attacks and Mitigations*. NIST AI 100-2e2025.
- CISA (2025). *AI Cybersecurity Collaboration Playbook*.
- CISA, NSA, ASD, NCSC-UK et al. (2026). *Careful Adoption of Agentic AI Services*. https://media.defense.gov/2026/Apr/30/2003922823/-1/-1/0/CAREFUL%20ADOPTION%20OF%20AGENTIC%20AI%20SERVICES_FINAL.PDF
- CISA (2025). *Principles for the Secure Integration of AI in Operational Technology*. <https://www.cisa.gov/resources-tools/resources/principles-secure-integration-artificial-intelligence-operational-technology>
- OWASP (2025). *Top 10 for LLM Applications 2025*.

Aprendizaje automático aplicado a ciberseguridad

- Apruzzese, G., Laskov, P. & Schneider, J. (2023). SoK: Pragmatic Assessment of Machine Learning for Network Intrusion Detection. *IEEE EuroS&P 2023*.
- Schrötter, M., Niemann, L. & Schnor, B. (2024). A Comparison of Neural-Network-Based Intrusion Detection

against Signature-Based Detection in IoT Networks. *Information*, 2024.

- Khraisat, A. et al. (2019). Survey of intrusion detection systems: techniques, datasets and challenges. *Cybersecurity*, 2019.

Malware

- Anderson, H. S. & Roth, P. (2018). EMBER: An Open Dataset for Training Static PE Malware Machine Learning Models. arXiv:1804.04637. <https://arxiv.org/abs/1804.04637>
- Oesch, S. et al. (2023). Beyond the Hype: An Evaluation of Commercially Available Machine-Learning-Based Malware Detectors. *Digital Threats: Research and Practice*, 2023.

Industria / IA agéntica

- Karpathy, A. (2017). Software 2.0. *Medium*. <https://karpathy.medium.com/software-2-0-a64152b37c35>
- Yao, S. et al. (2022). ReAct: Synergizing Reasoning and Acting in Language Models. arXiv:2210.03629.
- Weng, L. (2023). LLM-powered Autonomous Agents. *Lilian Weng's Blog*. <https://lilianweng.github.io/posts/2023-06-23-agent/>
- CrowdStrike (sep. 2025). Charlotte AI — Fal.Con 2025.
- Microsoft (mar. 2025). Security Copilot Agents.

Gracias



Jesús Fernández Bes

Contacto:

contact@jesusfbes.es
<http://jesusfbes.es>



2026
CURSOS DE VERANO

Universidad Complutense de Madrid

ZARAGOZA